پنجره واحد خدمات هوشمند دانشگاهی

نحوه اتصال مراکز دانشگاهی به پنجره واحد دولت من(بخش فنی)

نسخه۱

USW.SSO.V02

۰۲۱۸۲۲۳۴۳۷۰-۲

ساختمان وزارت عتف، طبقه هشتم

اداره کل آمار، فناوری اطلاعات و امنیت

مقدمه

یکی از مهمترین نیازها برای تسهیل دسترسی به خدمات و سامانه‌ها، استفاده از ورود یکپارچه و احراز هویت متمرکز کاربران است. احراز هویت متمرکز که با عنوان SSO[1] شناخته می‌شود یکی از ابزارهای پایه به منظور فراهم شدن سرویسی است که در آن احراز هویت کابران در یک نقطه به صورت متمرکز انجام می‌شود و اطلاعات پایه در خصوص کاربران از منابع مطمئن برای استفاده دیگر سامانه‌های کاربردی فراهم می‌شود.

یکی از فعالیت‌های مهم و کلیدی که در برنامه دولت الکترونیکی کشور، اخیرا مورد توجه جدی بوده است، گسترش این سرویس در حوزه‌های مختلف دولت بوده است که هم اکنون در سطح ملی با عنوان پنجره واحد خدمات هوشمند دولت(دولت من)، عملیاتی شده است و سازمان‌های مختلفی نیز به آن متصل گردیده‌اند.

پنجره واحد خدمات هوشمند دانشگاهی با هدف تجمیع خدمات حوزه وزارت علوم و تسهیل دسترسی کاربران به آنها، توسعه یافته است و اهداف پنجره واحد خدمات هوشمند را مبتنی بر ضوابط اجرایی مرتبط در دولت الکترونیکی، دنبال می‌نماید. از طرفی سرویس SSO به صورت پس‌زمینه، مدیریت دسترسی کاربران را فراهم می‌نماید که ایده اصلی آن اتصال به پنجره واحد دولت من از یک طرف و کنترل قواعد و سیاست‌های وزارت علوم از طرف دیگر است. بنابراین در این نگرش، تمامی مراکز ارائه دهنده خدمت که مجوز فعالیت خود را از وزارت علوم دریافت می‌نمایند از طریق پنجره واحد خدمات هوشمند دانشگاهی، به پنجره واحد خدمات دولت هوشمند(دولت من)، متصل خواهند شد.

تعاریف پایه

دولت من: اشاره به پنجره واحد خدمات دولت هوشمند است که از طریق آدرس my.gov.ir، قابل دسترس است و امکان دسترسی به خدمات دولت را فراهم می‌نماید و سرویس احراز هویت متمرکز آن(sso.my.gov.ir)، ضمن احراز هویت اشخاص حقیقی و حقوقی، اطلاعات پایه آنها را برای استفاده سامانه‌های متصل به آن فراهم می‌نماید.

پنجره واحد خدمات هوشمند دانشگاهی: سامانه‌ای است که با آدرس USW.MSRT.IR در دسترس می‌باشد و وظیفه دسترسی یکپارچه به خدمات حوزه آموزش عالی کشور را مبتنی بر ضوابط اجرایی پیاده‌سازی پنجره واحد خدمات دولت الکترونیکی، برعهده دارد. در این مستند با عنوان USW به آن اشاره می‌گردد.

مرکز: اشاره به دانشگاه، سازمان‌های تابعه، پارک‌های علم و فناوری، مراکز پژوهشی، موسسه‌های آموزش عالی و یا هر مرکزی دارد که مجوز فعالیت خود را از وزارت علوم دریافت نموده است.

پنجره واحد خدمات مرکز: سامانه‌ای است که در این مستند به نام SPSW[2]، نام برده می‌شود که پنجره واحد خدمات یک مرکز می‌باشد.

[1] Single Sign On
[2] .Service Provider_ Single Window

۱ - سرویس احراز هویت متمرکز در USW

این بخش در برگیرنده اطلاعات فنی در خصوص نحوه اتصال سامانه‌های مرکز دانشگاهی به پنجره واحد خدمات دولت هوشمند(دولت من) است. این اتصال از طریق سرویس احراز هویت متمرکز در پنجره واحد خدمات دانشگاهی(USW SSO) صورت می‌گیرد که نقش واسط بین مراکز دانشگاهی و پنجره واحد دولت هوشمند را برعهده دارد.

در ابتدا، روال تبادل اطلاعات بین سامانه(یا پنجره واحد خدمات مرکز با عنوان SPSW) با سرویس احراز هویت متمرکز USW SSO، توضیح داده می‌شود که بر اساس پروتکل Outh2 می‌باشد. آنگاه اطلاعات فنی مورد نیاز و گام‌های فنی برای ایجاد ارتباط، شرح داده خواهد شد. اطلاعات این بخش بایستی در اختیار توسعه دهندگان سامانه‌ها، قرار گیرد.

در احراز هویت متمرکز (با توجه به شکل ۱)، وظیفه ورود کاربران برای تمامی مراکز برعهده سرویس USW SSO، محول می‌شود که همان سرویس احراز هویت متمرکز در پنجره واحد خدمات هوشمند دانشگاهی است. در شکل ۱ تعاملات بین دو طرف سرویس ورود پنجره واحد مرکز(SPSW Login) و USW SSO، نشان داده است که سناریوی کلی آن در اینجا آورده می‌شود و جزئیات تعریف پیام‌ها و داده‌های ارسالی در ادامه خواهد آمد.

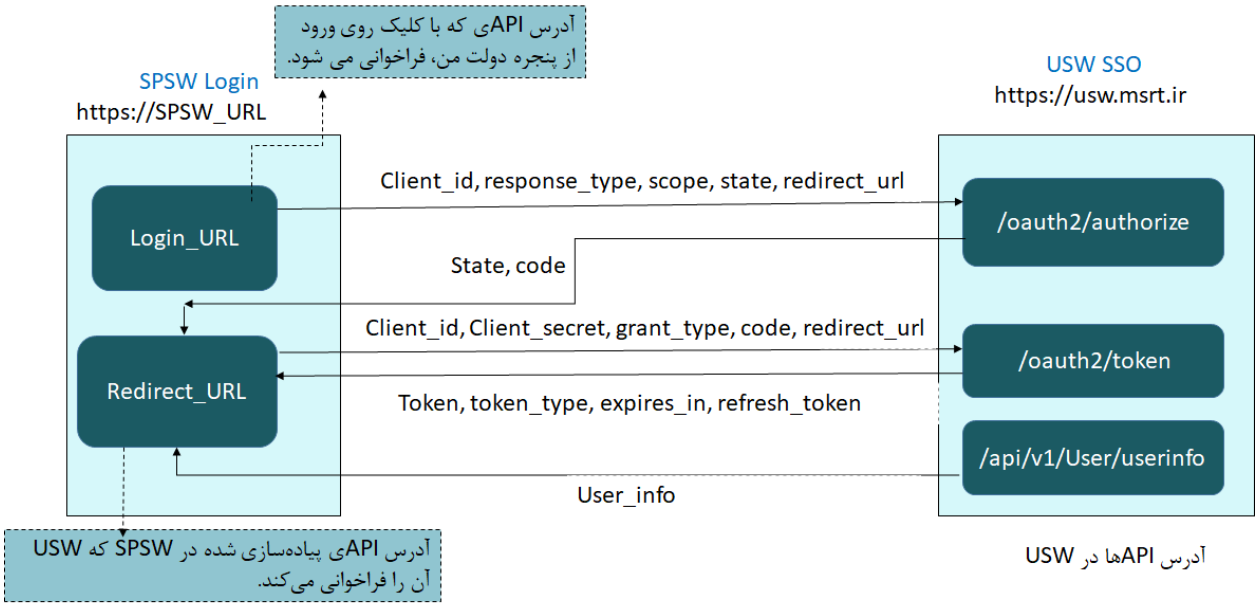
۱. وقتی که کاربری در صفحه ورود روی گزینه "ورود از پنجره واحد دولت من" کلیک می کند، آنگاه پردازشی(یا APIی) با نام مثالی login فراخوانی می‌شود که درخواست ورود را با ارسال پیامی به سرویس Authorize_URL، هدایت می‌کند.

۲. با دریافت پیام در سرویس Authorize_URL، پیام تاییدی بر می‌گردد که دارای کد موقتی (code) است که به آن مرکز نسبت داده می‌شود (بازگشت ازUSW SSO به redirect_url در SPSW).

۳. پنجره واحد مرکز از طریق سرویسی مانند Redirect_URL، درخواست ورود را به سرویس token در USW SSO خواهد داد.

۴. با تایید اطلاعات، ورود کاربر در USW SSO صورت پذیرفته و اطلاعات توکن به پنجره واحد مرکز برگشت داده می‌شود که شامل اطلاعات کاربر لاگین شده است.

۵. سرویس Redirect_URL، با دریافت توکن نسبت به ایجاد نشست با کاربر و ایجاد توکن محلی، اقدام می‌نماید و درخواست اطلاعات کاربر را به سرویس USW SSO، خواهد داد.



نکته: اسامی در سمت مرکز مثالی هستند و برنامه نویس می تواند تغییر دهد.

شکل ۱- پیام‌های مبادله شده بین طرفین در احراز هویت متمرکز

۲- گام‌های اتصال به USW SSO

به طور کلی برای اتصال باید دو مرحله اصلی را انجام داد. در مرحله اول بایستی اطلاعات پایه فنی در خصوص سامانه(متقاضی اتصال که اینجا با عنوان SPSW نام برده می‌شود) توسط مرکز دانشگاهی در اختیار USW SSO قرار می‌گیرد (مرحله ۱). مرحله دوم گام‌های فنی اتصال توسط توسعه دهنده با تعامل با پشتیبان فنی USW SSO، انجام می‌پذیرد که در جدول ۱، شرح کوتاه گام‌ها، ارائه شده است و جزئیات آن در ادامه خواهد آمد.

جدول ۱- مراحل و گام‌های فنی اتصال به USW SSO

شماره مرحله	عنوان مرحله	عنوان گام	شرح گام	متولی	
۲-۱	تخصیص شناسه‌های یکتا	ثبت اطلاعات فنی و پایه سامانه	در این مرحله اطلاعات فنی مورد نیاز از سامانه(مورد تقاضا برای اتصال)، وارد می‌شود. این اطلاعات بایستی توسط توسعه دهنده سامانه در اختیار نماینده دانشگاه قرار گیرد که در سامانه USW، ثبت گردد.	مرکز دانشگاهی	بخش ۲-۱-۱
		تخصیص شناسه یکتا	در این گام، شناسه‌های یکتا برای اتصال آن سامانه بر اساس پروتکل Outh، تعیین می‌شوند. این شناسه‌ها در اختیار توسعه دهنده سامانه مذکور، قرار داده می‌شود.	وزارت عتف	بخش ۲-۱-۲
۲-۲	اتصال به USW و تایید آن	اضافه کردن گزینه "ورود از طریق دولت من"	در این مرحله،گزینه‌ای در صفحه ورود به پنجره واحد خدمات مرکز، اضافه می‌گردد که امکان ورود از پنجره واحد خدمات دولت هوشمند را نیز فراهم می‌نماید. پنجره واحد خدمات دانشگاه به عنوان واسطی در این ارتباط، عمل می‌نماید.	مرکز ارائه دهنده خدمت	بخش ۲-۲-۱
		احراز هویت کاربر در USW	در این مرحله کاربر از طریق پنجره واحد خدمات دولت هوشمند(دولت من) و یا USW (صفحه ورود)، احراز هویت می‌گردد و مجددا به صورت اتوماتیک به صفحه اصلی پنجره واحد خدمات مرکز، برگشت داده می‌شود .	وزارت علوم	بخش ۲-۲-۲
		دریافت توکن و ایجاد نشست	در این مرحله درخواست ورود کاربر از سوی USW به صفحه اصلی پنجره واحد خدمات مرکز با ارسال توکن امنی برگشت داده شده است و بر اساس آن امکان ورود کاربر به SPSW با ایجاد نشست یا توکن جدید، فراهم می‌شود.	مرکز ارائه دهنده خدمت	بخش ۲-۲-۳
		درخواست اطلاعات کاربر	در این مرحله اطلاعات هویتی کاربر از طریق فراخوانی یک API از USW، دریافت خواهد	مرکز ارائه دهنده	بخش ۲-۲-۴

			شد و مرکز بر حسب آن نقش ورورد کاربر را مشخص خواهد نمود.	خدمت	
		مدیریت خروج از سامانه	در این مرحله، بایستی رویکردی برای خروج از USW SSO و یا سامانه محلی، در نظر گرفته شود.	مرکز ارائه دهنده خدمت	بخش ۵-۲-۲
		بررسی سامانه متصل شده	در این مرحله سامانه متصل شده بررسی می‌گردد و اطمینان حاصل می‌شود که ضوابط اجرایی پنجره واحد خدمات دولت در نظر گرفته شده است.	وزارت عتف	بخش ۶-۲-۲

۱-۲- تخصیص توکن SSO

هدف این مرحله تخصیص شناسه‌های یکتا به سامانه(متقاضی اتصال) است که شامل دو گام است که در گام اول اطلاعات فنی و پایه سامانه وارد می‌شود و در گام بعدی شناسه‌های یکتایی برای آن سامانه، تعریف می‌شود.

۱-۱-۲- ثبت اطلاعات فنی و پایه سامانه

در این مرحله با همکاری شرکت توسعه دهنده، اطلاعات پایه فنی سامانه(متقاضی اتصال)، در فرم مرتبط(شکل ۲)، وارد می‌گردد. فیلدهای مورد نیاز در این فرم به شرح زیر است. مهمترین جنبه برای ایجاد ارتباط آسان و سریع، دقت کافی در ثبت این اطلاعات می‌باشد. بر این اساس، هر گونه ابهامی را می‌توانید با پشتیبان فنی سامانه USW SSO، در میان بگذارید.

- **آدرس صفحه اصلی در پنجره واحد خدمات مرکز:** آدرس صفحه‌ای است که بعد از ورود کاربران در دسترس قرار می‌گیرد و اصطلاحا صفحه اصلی است. این صفحه با عنوان URL برگشتی از USW شناخته می‌شود و فرمتی مانند https://SPSW_URL/MainPage ، دارد. در بسیاری از سامانه‌ها این صفحه با عناوینی مانند Index و Main، شناخته می‌شود.
- **آدرس URL ورود کاربران در پنجره واحد خدمات مرکز:** منظور آدرس URL صفحه، API و یا آن routeی است که پردازش ورود کاربران را انجام می‌دهد (فرمتی مانند https://SPSW_URL/Login_URL در این مستند). در زمانی که روی گزینه "ورود از پنجره واحد دولت من" کلیک شده است و یا اینکه کاربر در سامانه ی USW روی ورود به مرکز کلیک کرده است، آدرس وارد شده در این بخش فراخوانی می‌شود و درخواست را با اطلاعات مشخص شده در شکل ۱ به https://usw.msrt.ir/oauth2/authorize هدایت می‌کند و مراحل احراز هویت و بازگشت به مرکز انجام می‌شود.
- **آدرس برگشتی (Redirect URL):** آدرس API و یا Routeی است که توسط USW SSO، فراخوانی می‌شود و درخواست احراز هویت کاربر را برای دریافت توکن به سرویس https://usw.msrt.ir/oauth2/token، ارسال می‌نماید. در این مستند فرمتی مشابه (فرمتی مانند https://SPSW_URL/Redirect_URL، دارد.

نکته: لازم است اطلاعات فوق به همراه اطلاعات تماس مسئول فنی برای هماهنگی و رفع مشکلات فنی، درج گردد. در نظر بگیرید که گزینه آدرس صفحه خروج به صورت انتخابی است. بعلاوه، آدرس‌های کلاینت تستی را زمانی بزنید که می‌خواهید ابتدا روند اتصال را با یک سامانه و کد تستی انجام دهید و بعد به سامانه اصلی مرکز، منتقل کنید.



شکل ۲- صفحه ثبت اطلاعات فنی سامانه مرکز(با یک نمونه مثال)

۲-۱-۲- تخصیص شناسه یکتا

در این مرحله، درخواست مرحله قبل توسط همکاران مرتبط با USW در وزارت علوم بررسی و در صورت تایید، دو شناسه یکتا برای ثبت مرکز ارائه دهنده خدمت، صادر می‌گردد و از طریق کارتابل نماینده دانشگاه در اختیار مرکز قرار می‌گیرد. دو شناسه مورد اشاره به صورت زیر است:

- client_id: شناسه‌ای است که برای اشاره به یک سامانه متصل به USW اشاره دارد (در اینجا پنجره واحد مرکز)
- client_secret: یک کد رمز برای شناسایی سامانه‌ای است که به USW متصل شده است که متناسب با client_id است. به عبارتی به مشابه گذر واژه برای مرکزی (سامانه‌ای) است که شناسه آن client_id است.

نماینده دانشگاه با مراجعه به کارتابل خود در USW از طریق گزینه درخواست‌های من و یافتن درخواست مربوطه و با کلیک روی گزینه "پیگیری"، به دو شناسه فوق، دسترسی می‌یابد. این دو شناسه برای اصلاح کد ورود کاربران در پنجره واحد خدمات مرکز، استفاده می‌گردد که در ادامه توضیح داده خواهد شد.

۲-۲- اتصال سامانه به USW و تایید آن

فعالیت اصلی اتصال در این مرحله انجام می‌پذیرد که شامل گام‌های زیر، می‌باشد.

۲-۲-۱- اضافه کردن گزینه "ورود از طریق دولت من"

در این مرحله، مرکز بایستی در صفحه ورود کاربران در پنجره واحد مرکز یک گزینه با عنوان "ورود از طریق دولت من" را اضافه نموده.با انتخاب این گزینه بایستی پردازشی (مثلا در قالب یک API) فراخوانی شود که درخواست احراز هویت کاربر را به USW (با آدرس دقیق 'http://usw.msrt.ir/oauth2/authorize') هدایت نماید. در این درخواست لازم است چندین گزینه ارسال شود که عبارتند از:

- client_id: شناسه یکتایی که از طریق پنجره واحد خدمات دانشگاهی در اختیار شما قرار گرفته است.
- redirect_uri: همان آدرسی است که در مرحله ۳-۱، فراهم شده است.
- response_type: گزینه‌ای است که به نوع پاسخ سرویس احراز هویت متمرکز (اینجا USW) به درخواست‌ها دارد که به اطلاعات فنی پروتکل SSO مربوط می‌شود. در اینجا مقدار آن را برابر code به صورت رشته، قرار دهید.

- Scope: نوع محدوده کاری SSO را مشخص میکند و به صورت ثابت برابر openid profile به صورت رشته قرار دهید.
- State: متغیر تصادفی است که در پنجره مرکز تولید میگردد و بین طرفین مبادله میگردد. میتوانید آن را یک رشته تصادفی در نظر بگیرید.

```
[Route("Login_URL")]
[HttpGet]
public async Task<IActionResult> Login()
   {

var state = Guid.NewGuid().ToString().Replace("-", "");

HttpContext.Session.SetString("state", state);          //  state  تعریف پارامتر

var url = $"https://usw.msrt.ir/oauth2/authorize?response_type=code
         &scope=openid profile
        &client_id=client_id                                                    //تعریف پارامترهای درخواست
        &state={sate}
        &redirect_uri=http:// SPSW_URL/Redirect_URL";

 return Redirect(url);
     }
```

کد ۱- متدی برای ارسال درخواست احراز هویت به oauth2/authorize

نکته: ممکن است کاربری بدون مراجعه به پنجره واحد خدمات مرکز از طریق خود USW و یا غیرمستقیم از طریق پنجره واحد خدمات هوشمند دولت، وارد شده باشد و احراز هویت گردیده است. آنگاه در USW روی یک مرکز خاصی کلیک کرده باشد. در چنین حالتی نیز کاربر به صفحه آاصلی پنجره واحد خدمات مرکز، هدایت میگردد.

در این مرحله ،کد یکبار مصرفی از طریق USW برای پنجره واحد خدمات مرکز (در یک کانال امن مستقل) ارسال می‌گردد که شناسه‌ای برای تعامل بعدی است.

۲-۲-۲- احراز هویت کاربر در USW

در این مرحله USW از طریق سرویس احراز هویت متمرکز خود و یا با هدایت کاربر به سامانه ملی "پنجره واحد دولت هوشمند"، هویت کاربر را تشخیص می‌دهد. سپس بر اساس اطلاعات دریافتی از درخواست کاربر مانند client_id و response_type، پاسخ را در قالب درخواستی بر می‌گرداند که در واقع فراخوانی پردازش ورود کاربران در پنجره واحد مرکز است.

۳-۲-۲- دریافت توکن کاربر احراز هویت شده و ایجاد نشست

مهمترین فعالیت مرتبط با احراز هویت متمرکز که پنجره واحد مرکز بایستی انجام دهد، آن است که اطلاعات کاربر را از طریق پاسخ دریافت شده از USW، استخراج نماید. در پنجره واحد مرکز، کدی در پردازش ورود کاربران بایستی اضافه گردد که کارهای زیر را انجام دهد:

الف) ابتدا وضعیت درخواست واکشی و در گزینه state ذخیره میگردد.

ب) آنگاه درخواستی از نوع post و در قالب form data از طرف پنجره واحد مرکز به USW ارسال می‌گردد که درخواست توکن کاربر را خواهد نمود. اما برای دریافت توکن لازم است نشان دهد که کاربر و پنجره واحد مرکز همانی است که قبلا درخواست احراز هویت نموده است. بنابراین اطلاعات client_id،client_secret و کد موقت دریافتی (code) را مجددا به USW ارسال می‌نماید. فیلد grant_type در واقع کدی است که نوع مجوز مورد تقاضا از احراز هویت متمرکز را نشان می‌دهد. مقدار آن را برابر authorization_code، قرار دهید . قبل از ارسال توکن، بر اساس پروتکل‌های SSO کد یکبار مصرف دریافت شده به صورت سیستمی با USW مبادله میگردد که مشخص گردد دریافت کننده توکن همان کاربری از مرکز است که درخواست خود را قبل ارسال نموده است. این بخش به صورت اتوماتیک است .

ج) پنجره واحد مرکز توکن را دریافت نموده و بر اساس آن نسبت به ایجاد نشست (یا ایجاد توکن جدید) برحسب سیاست کاری خود، اقدام مینماید .

توجه: در صورتی که خطاهایی در این مرحله اتفاق افتد، به صورت زیر گزارش خواهند شد:

شناسه خطا	شرح
"error": "invalid_request"	زمانی که درخواست دریافتی در سرویس authorize نادرست باشد(مثلا مقدار تهی داشته باشد.)
"error": "invalid_client"	در صورتی که Authoization ایجاد شده با Client_id و Client_secret، برابر نباشد.
"error": "unsupported_grant_type"	شرایطی که مقدار invalid_grant دریافتی نامعتبر باشد، مثلا استفاده مجدد از یک کد صورت گیرد.
"error": "invalid_scope"	در صورتی که scope دارای مقدار نامعتبری باشد .
"error": "redirect_uri_mismatch"	درصورتی که مقدار redirect_uri دارای مقدار نامعتبری باشد.

۴-۲-۲- واکشی اطلاعات کاربر احراز هویت شده

واکشی اطلاعات پروفایل کاربر از توکن دریافت شده که به صورت رمزگذاری شده ارسال شده است، بایستی در این مرحله با اضافه شدن کد متناسب در تابع ورود سامانه پنجره واحد خدمات مرکز، اضافه گردد(کد ۲).

الف) درخواست دریافت اطلاعات کاربر بر حسب توکن دریافت شده به USW ارسال میگردد.

ب) اطلاعات کاربر احراز هویت شده بر اساس فرمت و ساختار مشخصی از سمت USW ارسال می‌گردد. این اطلاعات برحسب نوع

ج) ورود کاربر میتواند شامل اطلاعات مختلفی مانند اطلاعات هویتی، آدرس، عکس و موارد مشابه باشد.

د) اطلاعات دریافت شده در حال حاضر شامل اطلاعات پایه هویتی است که در جدول زیر مشاهده میگردد. این اطلاعات در ساختار برگشتی ProfileRequest برگشت داده میشوند که همگی از نوع رشته هستند.

{id,nationalId, firstName, lastName, fatherName, mobile, gender, birthDate, shenasnamehNo, postalCode, province, city}

```
 [Route("Redirect_URL")]
     [HttpGet]
     public async Task<IActionResult> Redirect([FromQuery] string? code, [FromQuery] string? state)
     {
        var stateCheck = HttpContext.Session.GetString("state");
        if (string.IsNullOrEmpty(stateCheck&& stateCheck==state )    //state کنترل برابری
        {
           return BadRequest();
        }
        var httpClient = _clientFactory.CreateClient();
   httpClient.Timeout = TimeSpan.FromSeconds(180);
//تعریف پارامترهای درخواست به صورت فرم دیتا برای دریافت توکن
using MultipartFormDataContent multipartContent = new MultipartFormDataContent();
        multipartContent.Add(new StringContent("authorization_code", Encoding.UTF8, MediaTypeNames.Text.Plain), "grant_type");
        multipartContent.Add(new StringContent(code, Encoding.UTF8, MediaTypeNames.Text.Plain), "code");
        multipartContent.Add(new StringContent("openid profile", Encoding.UTF8, MediaTypeNames.Text.Plain), "scope");
        multipartContent.Add(new StringContent("http:// SPSW URL/Redirect_URL" , Encoding.UTF8,
MediaTypeNames.Text.Plain), "redirect_uri");
        multipartContent.Add(new StringContent("client_id", Encoding.UTF8, MediaTypeNames.Text.Plain), "client_id");
       //باید با مقداری که تخصیص داده می شود برابر شود(بخش ۲-۱-۲)
        multipartContent.Add(new StringContent("client_secret", Encoding.UTF8, MediaTypeNames.Text.Plain), "client_secret");
       //باید با مقداری که تخصیص داده می شود برابر شود(بخش ۲-۱-۲)

//ارسال درخواست و دریافت توکن
        var tokenResponse = await httpClient.PostAsync("https://usw.msrt.ir/oauth2/token",
           multipartContent);

 if (tokenResponse.IsSuccessStatusCode)
        {
           var tokenReadAsString = await tokenResponse.Content.ReadAsStringAsync();

           var resultToken = JsonSerializer.Deserialize<OAuthResponseToken>(tokenReadAsString);
           var token = resultToken.access_token;   //  استخراج توکن از پاسخ دریافت شده

           httpClient.DefaultRequestHeaders.Authorization = new AuthenticationHeaderValue("Bearer", token);
           var jwksResponse = await httpClient.GetAsync("https://usw.msrt.ir/oauth2/jwks");    //بررسی صحت توکن دریافتی
           if (jwksResponse.IsSuccessStatusCode)
           {
            var userInfoResponse = await httpClient.GetAsync("https://usw.msrt.ir/api/v1/User/userinfo");//اطلاعات کاربر
                    if (userInfoResponse.IsSuccessStatusCode)
                    {
               var userInfoReadAsString = await userInfoResponse.Content.ReadAsStringAsync();
               var resultUserInfo = JsonSerializer.Deserialize<ProfileRequest>(userInfoReadAsString);
              }
           }
           else
           {
              return BadRequest();    //تابعی برای کنترل خطاها که برنامه نویس می تواند در نظر بگیرد
           }
        }
        else
        {
           return BadRequest();
        }
     }
```

کد ۲- دریافت توکن، ایجاد نشست و دریافت مشخصات کاربر

نکته: در مواردی سامانه SPSW بخواهد وضعیت یک توکن را در طول زمان لاگین کاربر از USW، درخواست نماید. کد زیر در هر مرحله میتواند در این خصوص به کار آید که نشان دهد آیا توکن همچنان معتبر است یا خیر .

```
var jwksResponse = await httpClient.GetAsync("https://usw.msrt.ir/oauth2/jwks");

if (jwksResponse.IsSuccessStatusCode){
    // توکن صحیح است.
}
```

کد ۳- کنترل صحت توکن دریافت شده

۵-۲-۲- مدیریت خروج از سامانه متصل شده

یکی از موارد مهم در موضوع احراز هویت متمرکز، مدیریت خروج از سامانه متصل شده و یا خروج از سامانه احراز هویت متمرکز است. فردی که از طریق سامانه احراز هویت متمرکز (مانند USW SSO) به یک سامانه وارد شده است، یک توکن معتبر برای دسترسی به این سامانه را برای مدت زمانی در اختیار دارد. اگر این فرد از این سامانه بخواهد خروج کند، بایستی تمهیداتی برای حفظ و یا انقضای توکن در نظر گرفته شود. موارد زیر در این خصوص، پیشنهاد داده می‌شود:

در زمان خروج از سامانه متصل شده(Logout): در صورتی که کاربر از طریق USW وارد سامانه شده است، لازم است در زمان خروج دو گزینه برای کاربر در نظر گرفته شود:

- الف) "خروج از سامانه و ماندن در پنجره واحد دولت من": در این حالت در صورت تمایل می‌توانید کاربر را به صفحه پنجره واحد USW، هدایت کنید.
- ب) "خروج همزمان از سامانه و پنجره واحد دولت من": در این حالت سامانه متصل شده بایستی درخواست خروج را به صفحه Logout در USW (با آدرس https://usw.msrt.ir/oauth2/logout)، هدایت(redirect) نماید.

نکته ۱: در صورتی که در یک مرکز، سامانه به احراز هویت متمرکز داخلی متصل شده است، بایستی صفحه Logout از آن سامانه فراخوانی شود، سامانه احراز هویت متمرکز داخلی مرکز نیز بایستی توکن کاربر را منقضی و کاربر را به صفحه Logout در USW، هدایت نماید.

نکته ۲: مدیریت نشست کاربر با سامانه متصل شده برعهده خود سامانه است و لازم است برحسب سیاست داخلی سامانه، مکانیزم‌ها و تمهیداتی در نظر گرفته شده باشد.

۶-۲-۲- بررسی سامانه متصل شده

در این گام سامانه متصل شده توسط کارشناسان وزارت عتف، مورد بررسی قرار می‌گیرد و اطمینان حاصل می‌شود که اتصال به درستی انجام پذیرفته است و قواعد مرتبط در نظر گرفته شده است. اصلی‌ترین قواعد مرتبط در این خصوص عبارتند از:

- سامانه متصل شده مجددا نباید درخواست ورود به کاربری دهد که از طریق پنجره دولت من، وارد شده است.
- اطلاعات مختصر پروفایل فرد در کنار گزینه ورود، نمایش داده شود.

- سامانه‌هایی که برای یک فرد جدید نیاز به تکمیل پروفایل دارند بایستی بعد از ورود اولیه نسبت به انجام آن اقدام نمایند و یا رمزی را به فرد لاگین شده از پنجره دولت، به صورت اتوماتیک ایجاد و ارسال نماید. در هر حال، به هیچ وجه نباید مجددا درخواست ورود نام کاربری و رمز از کاربری شود که از طریق پنجره دولت من، احراز هویت شده است.
- الزامات و ضوابط اجرایی دولت در خصوص پنجره واحد خدمات دستگاه اجرایی با دیدگاه موارد کلیدی، کنترل می‌شود. بعد از بررسی سامانه متصل شده و تایید آن، آیکن مرکز دانشگاهی و سامانه‌های مرتبط در صفحه اصلی پنجره واحد خدمات دانشگاهی، نمایش داده می‌شود.

پیوست ۱– کدهای مستند با زبان PHP

```
use Illuminate\Http\Request;
use Illuminate\Support\Str;
use Illuminate\Support\Facades\Http;
Route::get('Login_URL', function (Request $request) {
   $request->session()->put('state', $state = Str::random(40));
   $query = http_build_query(['client_id' => ۲-۱-۲ کد تخصیصی مطابق بخش',
      'redirect_uri' => 'Redirect_URL,
      'response_type' => 'code',
      'scope' => 'profile',
      'state' => $state,
    ]);
   return redirect('https://usw.msrt.ir/oauth2/authorize?'.$query);

});
```

تابع یا پردازشی که در سمت SPSW زمان کلیک روی "ورود از پنجره واحد دولت من"، بایستی نوشته شود .

مقدار دهی متغیرها نیز در این بخش نشان داده شده است.

کد ۴- متدی برای ارسال درخواست احراز هویت به oauth2/authorize

```
Route::get('Redirect_URL', function (Request $request) {
 $state = $request->session()->pull('state');
 throw_unless(strlen($state) > 0 && $state === $request->state,
InvalidArgumentException::class
  );
  $response = Http::asForm()->post('https://usw.msrt.ir/oauth2/token', [
   'grant_type' => 'authorization_code',
    'client_id'=>۲-۱-۲ کد تخصیص یافته مطابق بخش ,
     'client_secret'=>۲-۱-۲ کد تخصیص یافته مطابق بخش,
     'redirect_uri' =>'Redirect_URL',
      'code' => $request->code,
      'scope' =>'openid profile',
  ]);
  $res = $response->json();
 $jwt = $res['access_token'];
```

گرفتن متغیر State و مقایسه آن با آنچه که باید باشد. در صورت تهی بودن و یا نابرابری ،خطا برگشت داده می شود.

درخواست برای دریافت توکن احراز هویت کاربر از سامانه USW و مقداردهی به متغیرهای مورد نیاز در درخواست. پارامتر ها در قالب FormData ارسال شود.

توکن احراز هویت در این بخش دریافت می شود و سامانه متقاضی می تواند نشست یا توکن خود را بسازد.

```
$response=Http::withHeaders([ 'Authorization'=>'Bearer'.$jwt])-
>get('https://usw.msrt.ir/api/v1/User/userinfo');

$userInfo= $response->json();

});
```

درخواست پروفایل

شکل ۵- کد دریافت توکن، ایجاد نشست و دریافت مشخصات کاربر

```
$response = Http::withHeaders(['Authorization'=> 'Bearer '. $jwt])-
>get('https://usw.msrt.ir/oauth2/jwks');
$checkToken = $response->ok();
```

اگر ویژگی status Code متغیر برگشتی checkToken در پاسخ دریافتی برابر 200 باشد به معنی صحت توکن ارسالی است و در غیر اینصورت توکن معتبر نیست.

کد ۶- کنترل صحت توکن در هر جا از کد که مورد نیاز است.

```
return redirect('https://usw.msrt.ir/oauth2/logout');
```

کد ۷- دستور خروج از سامانه USW